

Simulation and Detection of SSH-Based Botnet Attacks

Anna Poglitsch David Azevedo da Silva Rúben Jordão Oliveira Wendell Gustavo Ferreira Pinto
up202511830@edu.fe.up.pt up202104721@edu.fe.up.pt up202205106@edu.fe.up.pt up202200049@edu.fe.up.pt

Abstract—The Mirai malware is known for some of the largest and most disruptive distributed denial-of-service (DDoS) attacks. It infects Linux-based devices and turns them into remotely controlled bots for large-scale network attacks. This experiment explores the phases of a botnet attack. The project focuses on a virtual Linux environment with a containerized network environment. Additionally, it evaluates various defense scenarios by testing their effectiveness against SSH-based attacks inspired by Mirai malware, including automated IP banning via Fail2Ban, firewall-based IP blocking and rate limiting via iptables, and disabling password-based authentication entirely. To gain better insight into the expected results, these scenarios are evaluated using different criteria related to security and effectiveness. This approach aims to provide an overall view of the attack’s impact and evaluate the effectiveness of the countermeasures.

I. INTRODUCTION

Cyberattacks increasingly involve multi-stage invasion techniques that combine information gathering, credential attacks, lateral movement, and command-and-control communication. Understanding how these attacks evolve inside target environments is essential to understand which protection mechanisms are successful and which ones are not.

The SSH protocol, while secure by design, is frequently misconfigured in production environments, especially through the use of weak passwords and enabled password authentication. This makes SSH a common entry point for automated botnet propagation, as demonstrated by malware families such as Mirai, which systematically scans for and exploits weak SSH credentials to enlist devices into botnets.

The lab uses Podman-based containerized hosts connected through segmented networks to emulate a realistic infrastructure and attack scenarios. The environment consists of two isolated network segments, an external attack network and an internal protected network, separated by a dual-homed pivot host. This topology mirrors real enterprise architectures where an attacker must first compromise a perimeter machine before reaching internal systems.

The objective of the project is to study attacker behavior across the full attack lifecycle, analyze detection opportunities at each phase, and evaluate the effectiveness of defensive mechanisms. Specifically, the following countermeasures are studied and compared:

- **Fail2Ban** — automated IP banning after a configurable number of failed login attempts
- **Firewall IP blocking** — manual iptables rules that drop all traffic from a known attacker IP

- **SSH rate limiting** — iptables connection rate limiting to slow brute-force attempts
- **Disabling password authentication** — configuring SSH to accept only key-based authentication, eliminating the attack vector entirely

A. Motivation

Traditional cybersecurity projects or labs often focus on isolated attack techniques without demonstrating the complete attack lifecycle. However, real-world intrusions typically involve multiple sequential phases before, during, and after an attack.

The motivation behind this project is to understand the full chain of an SSH-based botnet attack, from initial reconnaissance and credential brute-forcing, through network pivoting and lateral movement into segmented internal networks, to command-and-control communication. By simulating this complete attack chain in a controlled environment, different protection mechanisms can be systematically applied and compared in terms of their effectiveness and limitations.

B. Proposed Approach

Our approach was structured into three focused phases, each designed to be completed within a two-month timeline:

Phase 1: Project Setup (Week 1-2)

This phase focused on understanding the scope of the project and setting up the environment.

- Isolated network (VirtualBox)
- Containers
- Network configuration (isolated networks)
- Security tools (Fail2Ban, iptables)
- Monitoring tool (custom Python detection engine)

Phase 2: Exploitation and Analysis (Week 3-6)

The aim of this phase was to exploit all vulnerabilities and analyze their performance.

- Exploitation of weak passwords via SSH brute-force, lateral movement through network pivoting, honeypot triggering, and command-and-control beaconing
- Evaluation of defensive countermeasures: Fail2Ban, firewall IP blocking, SSH rate limiting, and disabling password authentication
- Analysis of compromise rate, success rate, failure rate
- Documentation of findings

Phase 3: Documentation (Week 7-8)

This phase aimed to document all findings and contextualize

them within the scope of the study.

- Document each measurement
- Compare and rank security mechanisms
- Prepare for presentation

C. Tools and Technologies

Free and open-source tools and technologies were used throughout the project.

- **Virtualization and Containers:** VirtualBox, Podman
- **Operating System:** Kali Linux
- **Network Architecture:** attack_net, internal_net
- **Programming Language:** Python
- **Networking and Security Tools:** SSH, Nmap, Netcat, Fail2Ban, iptables
- **Monitoring and Analysis:** Custom Python Detection Engine
- **Honeypot Technology:** Honeypot Container
- **Documentation and Recording:** Prism, OBS Studio

D. Expected Results

The experiment is expected to demonstrate that undefended SSH servers with weak password authentication are highly vulnerable to automated brute-force attacks, and that a botnet can autonomously propagate across segmented networks by exploiting a dual-homed pivot host. Among the evaluated countermeasures, disabling password authentication is expected to be the most effective, as it eliminates the attack vector entirely regardless of password strength. Fail2Ban and firewall IP blocking are expected to significantly reduce the attack surface when applied proactively, while rate limiting is expected to slow but not fully prevent a determined attacker. The combination of multiple defenses is expected to provide the strongest protection, consistent with the defense-in-depth principle.

II. IMPLEMENTATION & FINDINGS

The implementation consists of a containerized environment designed to simulate realistic attack and defense scenarios within an isolated network infrastructure. The system includes multiple virtualized hosts connected through segmented networks representing external and internal environments. Using this setup, several offensive security techniques were implemented and tested. Four defensive countermeasures were subsequently applied and evaluated: automated IP banning via Fail2Ban, firewall-based IP blocking via iptables, SSH connection rate limiting, and disabling password-based SSH authentication.

The first scenario consisted of a single network (172.21.0.0/24) containing one attacker, two victim machines, and one monitoring client. In this setup, all hosts were directly visible and reachable by the attacker. Figure 1 presents the number of compromised hosts for each defense configuration. In the baseline scenario, all three victim machines were successfully compromised. The introduction of defensive mechanisms significantly reduced the attacker's success rate. Rate limiting and the combination of fail2ban with rate limiting completely prevented host compromise, while the

remaining defenses reduced the number of compromised hosts to one.

The first scenario consisted of a single network (172.21.0.0/24) containing one attacker, two victim machines, and one monitoring client. In this setup, all hosts were directly visible and reachable by the attacker. Figure 1 presents the number of compromised hosts for each defense configuration. In the baseline scenario, all three victim machines were successfully compromised. The introduction of defensive mechanisms significantly reduced the attacker's success rate. Rate limiting and the combination of fail2ban with rate limiting completely prevented host compromise, while the remaining defenses reduced the number of compromised hosts to one.

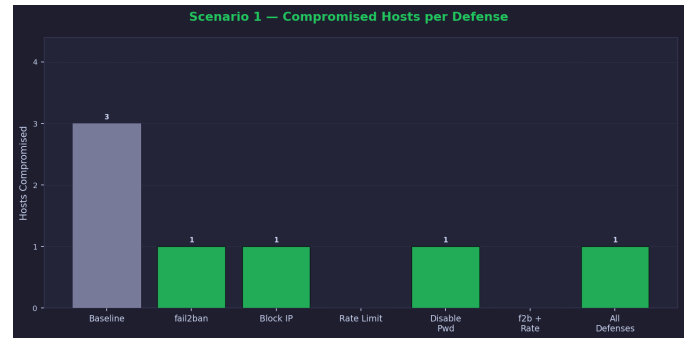


Fig. 1. Number of compromised hosts in Scenario 1 for each defense configuration.

In the second scenario, the attacker was required to pivot through Victim 1, a dual-homed host connected to both networks, in order to access the protected internal network (10.10.0.0/24).

The third scenario extended the attack chain by requiring the attacker to pivot further through Victim 2 to reach additional internal systems.

Finally, the fourth scenario focused on accessing the deeper internal segment (10.30.0.0/24) by pivoting through Victim 3, thereby simulating multi-stage lateral movement within a segmented enterprise network.

III. RESULTS

The experiments demonstrate that SSH-based brute-force attacks can successfully compromise and propagate through segmented networks when no defenses are applied. Across all scenarios, the baseline configuration consistently resulted in the highest number of compromised hosts, successful authentications, and lateral movement events. The introduction of defensive mechanisms significantly reduced attacker success and limited network pivoting. The first scenario shows that even in a flat network, basic SSH hardening measures substantially reduced attack success. Rate limiting proved to be the most effective standalone defense. In the second scenario the attacker successfully reached the internal network and compromised four hosts. Network segmentation alone was insufficient once the pivot host was compromised. However, combining

segmentation with SSH defenses effectively blocked lateral movement and prevented propagation into internal systems. Scenario 3 simulated deeper network traversal through multiple pivot points. The attacker compromised four hosts and made successful lateral movement. As attack depth increased, single defensive mechanisms became less effective. Defense-in-depth strategies combining multiple controls were required to prevent multi-stage compromise and lateral movement. In the last scenario the attacker accessed a deeply segmented internal network. Figure 2 shows that eight hosts were successfully compromised, enabling the attacker to propagate across three network layers via lateral movement. The effectiveness of layered defenses became increasingly important as network complexity increased. Deep network architectures amplified the impact of successful pivoting, making combined defensive controls essential. The experiments confirm that SSH-based

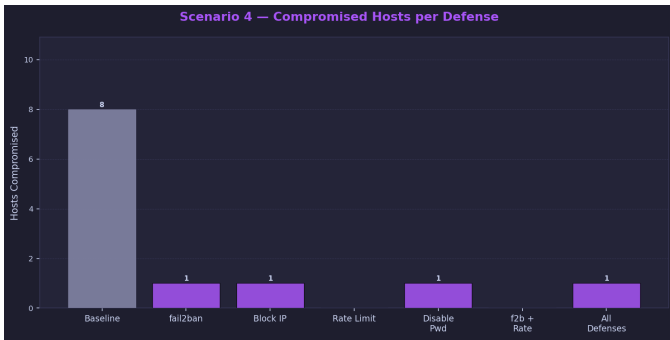


Fig. 2. Number of compromised hosts in Scenario 4 for each defense configuration.

botnet attacks can rapidly spread through segmented infrastructures when weak authentication and insufficient protections are present. While individual countermeasures reduced attacker success, the most reliable protection was achieved through layered defensive mechanisms combining authentication hardening, rate limiting, and automated blocking.

IV. RELATED WORK

One of the major inspirations for this project was the Mirai botnet, which became widely known after launching large-scale distributed denial-of-service (DDoS) attacks in 2016 [1]. Mirai demonstrated how weak credentials and insecure remote administration services could be exploited to compromise large numbers of devices and create scalable botnet infrastructures. Additional work on IoT and SSH-based attacks emphasizes that weak passwords and insecure remote services remain among the most common attack vectors in enterprise and IoT environments.

REFERENCES

- [1] J. Margolis, T. T. Oh, S. Jadhav, Y. H. Kim, and J. N. Kim, “An in-depth analysis of the mirai botnet,” in *2017 International Conference on Software Security and Assurance (ICSSA)*, 2017, pp. 6–12.